

Threat Intelligence Report: Simulated APT Campaign

Réalisé par : TINGO Mik

Email : tinigojeanmikcomlan@gmail.com

LinkedIn : <https://www.linkedin.com/in/jean-mik-c-tinigo>

SOMMAIRE

SOMMAIRE..... 2

Executive Summary..... 3

Threat Actor Profile 4

Campaign Overview..... 5

Technical Analysis..... 6

Detection & Hunting 8

Recommendations 14

Executive Summary

Between January and February 2026, two coordinated malware campaigns were detected targeting Windows endpoints across the West African region.

- **Campaign 1 : Lumma Stealer (January 2026)**

A credential-stealing malware exfiltrating browser credentials (Chrome, Edge) via an HTTP C2 channel. Victim: one confirmed Windows host (DESKTOP-ES9F3ML). Data at risk: saved passwords, session cookies, cryptocurrency wallets.

- **Campaign 2 : NetSupport RAT (February 2026)**

A Remote Access Trojan providing persistent control over compromised machines via HTTP beaconing to 45.131.214.85. Active C2 session maintained for 4+ hours. Lateral movement indicators observed (SMB + LDAP enumeration).

- **Assessment:**

Both campaigns share infrastructure characteristics and targeting patterns consistent with financially-motivated threat actors. The use of legitimate remote access tools (NetSupport) to blend with normal traffic suggests an actor with moderate-to-high operational security capability.

- **Recommended immediate actions :**

1. Block C2 IPs and domains at perimeter firewall
2. Deploy YARA rules on all endpoints
3. Audit browser credential stores on affected machines
4. Enable MFA on all external-facing services

Threat Actor Profile

Classification: Financially-motivated cybercriminal group

Suspected origin: Unknown, infrastructure hosted in multiple regions

Targeting: Windows endpoints, browser credential stores, corporate networks (SMB/LDAP enumeration observed)

Motivation: Financial gain, credential theft + remote access likely precursor to ransomware or BEC (Business Email Compromise)

Capability level: Moderate uses commodity malware (Lumma Stealer, NetSupport RAT) with operational security awareness

Aliases / Related campaigns:

- Lumma Stealer widely distributed via MaaS (Malware-as-a-Service) since 2022
- NetSupport RAT repurposed from legitimate IT tool, commonly used by TA577, TA578 threat groups

TTP Consistency across both campaigns:

- HTTP C2 communication on standard ports (80/443)
- Use of legitimate software signatures to evade detection
- Browser credential targeting as primary objective

Campaign Overview

Timeline

Date	Event
2026-01-27	First Lumma Stealer C2 contact detected (19:55 UTC)
2026-01-27	Active credential theft, Chrome + Edge agent
2026-01-27	4h21 of C2 beaconing before detection
2026-02-28	NetSupport RAT first contact (19:55 UTC)
2026-02-28	4h21 of persistent C2 session
2026-02-28	SMB + LDAP enumeration detected

Tableau 1 : Malware detection timeline

Geographic targeting

Both campaigns targeted hosts in the same IP range suggesting a focused regional campaign rather than opportunistic global scanning.

Infrastructure overlap

Both campaigns used port 443 for HTTP traffic (not HTTPS), a common technique to bypass firewall rules that allow outbound HTTPS.

Technical Analysis

4.1 - Lumma Stealer

Malware family: Lumma Stealer / LummaC2

Distribution: MaaS (Malware-as-a-Service)

First seen: 2022, actively developed

C2 Protocol :

- HTTP POST to /api/set_agent
- Parameters: id (victim ID), token (affiliate token), agent (target browser), act (action type)
- URL: `http://whitepepper.su/api/set_agent?`
`id=3BF67EC05320C5729578BE4C0ADF174C`
`&token=842e2802df0f0a06b4ed51f12f4387e761523b`
`&agent=Chrome`
`&act=log`

Credential theft mechanism:

Targets Chrome and Edge credential databases separately. The `agent` parameter indicates which browser is being actively exfiltrated.

Victim fingerprint extracted:

- Machine GUID: 3BF67EC05320C5729578BE4C0ADF174C
- Hostname: DESKTOP-ES9F3ML
- Username: Gabriel Wyatt (gwyatt)
- Domain: WIN11OFFICE / easyas123.tech

4.2 - NetSupport RAT

Malware family: NetSupport Manager (weaponized)

Type: Remote Access Trojan (RAT)

Legitimate software abused: NetSupport Manager v1.3

C2 Protocol:

- HTTP POST to /fakeurl.htm
- User-Agent: NetSupport Manager/1.3
- Server: NetSupport Gateway/1.92 (Windows NT)
- Beacons interval: ~60 seconds

Post-compromise activity:

- SMB traffic (port 445): 1,528 packets -> lateral movement attempt
- LDAP traffic (port 389): 1,138 packets -> Active Directory enumeration
- Domain discovered: easyas123.tech

4.3 - MITRE ATT&CK Mapping

Technique ID	Name	Campaign
T1071.001	Application Layer Protocol: HTTP	Both
T1555.003	Credentials from Web Browsers	Lumma Stealer
T1041	Exfiltration Over C2 Channel	Lumma Stealer
T1219	Remote Access Software	NetSupport RAT
T1571	Non-Standard Port	NetSupport RAT
T1018	Remote System Discovery	NetSupport RAT
T1083	File and Directory Discovery	NetSupport RAT
T1583.001	Acquire Infrastructure: Domains	Both

Tableau 2 : Mitre Att&ck Mapping

Detection & Hunting

5.1 - Suricata Rules

Suricata detection rules for various SQL injection attempt other http traffic :

- Lumma Stealer C2 detection

```
alert http any any -> $EXTERNAL_NET any (msg:"Lumma Stealer C2
/api/set_agent"; content:"/api/set_agent"; http_uri; nocase; content:"act=log";
http_uri; nocase; sid:2000001; rev:1;)
```

- NetSupport RAT C2 detection

```
alert http any any -> $EXTERNAL_NET any (msg:"NetSupport RAT /fakeurl.htm";
content:"/fakeurl.htm"; http_uri; nocase; content:"NetSupport Manager";
http_header; nocase; sid:2000002; rev:1;)
```

5.2 - YARA Rules

YARA rules deployed during month 4 for static malware analysis :

Rule 1 : Lumma Stealer C2 Pattern

```
rule Lumma_Stealer_C2_Pattern {
```

```
  meta:
```

```
    author    = "Mik"
```

```
    date      = "2026-09"
```

```
    description = "Detects Lumma Stealer C2 communication pattern"
```

```
    reference  = "SOC Home Lab - Month 1 PCAP Analysis (2026-01-31)"
```

```
    tlp       = "TLP:WHITE"
```

```
    mitre     = "T1071.001, T1555.003"
```

```
  strings:
```

```
    // C2 URI pattern from PCAP analysis
```

```
    $c2_uri    = "/api/set_agent" ascii nocase
```

```
    // Token parameter structure
```

```
    $c2_param  = "act=log" ascii nocase
```

```
    // Agent parameter for browser credential theft
```

```
    $agent_chrome = "agent=Chrome" ascii nocase
```

```

$agent_edge = "agent=Edge" ascii nocase
// Lumma Stealer User-Agent pattern
$ua = "Mozilla/5.0" ascii
condition:
  $c2_uri and
  ($c2_param or $agent_chrome or $agent_edge) and
  $ua
}

```

Rule 2 : NetSupport RAT Detection

```

rule NetSupport_RAT_C2 {
  meta:
    author    = "Mik"
    date      = "2026-09"
    description = "Detects NetSupport RAT C2 communication pattern"
    reference  = "SOC Home Lab - Month 1 PCAP Analysis (2026-02-28)"
    tlp       = "TLP:WHITE"
    mitre     = "T1219, T1071.001"
  strings:
    // Known C2 URI from NetSupport RAT
    $c2_uri = "/fakeurl.htm" ascii nocase
    // NetSupport Manager User-Agent signature
    $ua     = "NetSupport Manager" ascii
    // Server response banner
    $server = "NetSupport Gateway" ascii
  condition:
    $c2_uri and ($ua or $server)
}

```

Rule 3 : Generic PE Suspicious Strings

```
rule Suspicious_PE_Strings_v2
```

```

{
  meta:
    author    = "Mik"
    date      = "2026-09"
    description = "Detects suspicious PE behavior: credential theft, HTTP C2,
obfuscated PowerShell, process injection"
    tlp       = "TLP:WHITE"
    reference  = "https://attack.mitre.org/techniques/T1055/"
    version   = "2.0"

  strings:
    // Credential theft (strings spécifiques, pas "password" tout seul)
    $cred_1 = "Login Data"          ascii nocase // Chrome/Edge credential
DB
    $cred_2 = "CryptUnprotectData"  ascii nocase // Decryption API
DPAPI
    $cred_3 = "wallet.dat"          ascii nocase // wallets crypto
    $cred_4 = "Software\\Microsoft\\Windows\\CurrentVersion\\Credential"
ascii nocase
    $cred_5 = "logins.json"         ascii nocase // Firefox credentials

    // HTTP C2 (form-urlencoded POST = exfiltration classique)
    $http_1 = "Content-Type: application/x-www-form-urlencoded" ascii
    $http_2 = "Content-Type: multipart/form-data"             ascii
    $http_3 = "User-Agent: Mozilla/"                          ascii

    // Obfuscated PowerShell (EncodedCommand = base64)
    $ps_1 = "-EncodedCommand" ascii nocase
    $ps_2 = "-enc "      ascii nocase // abbreviated form
    $ps_3 = "-nop"       ascii nocase // -NoProfile
    $ps_4 = "FromBase64String" ascii nocase // .NET decode

    // Other useful TTPs

```

```

$misc_1 = "cmd.exe /c "   ascii nocase
$misc_2 = "schtasks /create" ascii nocase // persistence
$misc_3 = "reg add"       ascii nocase // persistence via registre

```

condition:

```

// Structural prerequisites: valid PE, reasonable size, unsigned
uint16(0) == 0x5A4D           // MZ header
and filesize < 5MB
and pe.number_of_sections > 0      // at least one PE section
and pe.number_of_sections < 16     // not some weird packed
binary

and ((2 of ($cred_*)) // Branch 1: credential theft, at least 2 indicators
or
// Branch 2: HTTP C2 : form-urlencoded header + another signal
(($http_1 or $http_2) and ($http_3 or 1 of ($cred_*)))
or
// Branch 3: Obfuscated PowerShell, at least 2 PS flags
(2 of ($ps_*))
or
// Branch 4: injection, actual imports into the PE table (NOT strings!)
(
  pe.imports("kernel32.dll", "VirtualAllocEx")
  and pe.imports("kernel32.dll", "WriteProcessMemory")
  and (
    pe.imports("kernel32.dll", "CreateRemoteThread")
    or pe.imports("kernel32.dll", "CreateRemoteThreadEx")
    or pe.imports("ntdll.dll", "NtCreateThreadEx")
  )
)
or
// Branch 5 : persistence (schtasks or reg add + cmd)

```

```
($misc_2 or $misc_3) and $misc_1
)
}
```

5.3 - Hunting Queries (OpenSearch DSL)

Hunt for Lumma Stealer C2 pattern in Wazuh

GET wazuh-alerts-*/_search

```
{
  "query": {
    "bool": {
      "must": [
        { "match": { "rule.description": "Suricata: Alert" } },
        { "wildcard": { "data.url": "*/api/set_agent*" } }
      ]
    }
  }
}
```

5.4 - Network Indicators to Block

Type	Value	Priority
IP	153.92.1.49	CRITICAL
IP	45.131.214.85	CRITICAL
Domain	whitepepper.su	HIGH
Domain	whooptm.cyou	HIGH
Domain	vadusa.xyz	MEDIUM

URI Pattern	/api/set_agent	HIGH
URI Pattern	/fakeurl.htm	HIGH
User-Agent	NetSupport Manager/*	HIGH

Tableau 3 : Network Indicators Referencing

Recommendations

This section is divided into three sections that provide some actions to take from the most imperative to the less :

Immediate (0-24h)

1. Block all C2 IPs and domains at perimeter firewall
2. Deploy YARA rules on endpoint detection platform
3. Audit active sessions, check for NetSupport processes
4. Reset credentials for affected user accounts

Short-term (1-7 days)

5. Deploy Suricata rules targeting URI patterns
6. Enable MFA on all external-facing services
7. Restrict outbound HTTP on port 443, enforce HTTPS only
8. Audit SMB and LDAP access logs for lateral movement

Long-term (7-30 days)

9. Implement browser credential protection (CyberArk, LAPS)
10. Deploy EDR solution with memory scanning capability
11. Conduct threat hunting for similar UA patterns across 90-day historical logs
12. Subscribe to threat intelligence feeds (MISP community) for real-time IOC sharing